

ISO/IEC 27701:2025

Seguridad de la información, ciberseguridad y protección
de la privacidad- Sistemas de gestión de la información
de privacidad - Requisitos y directrices

Contenido

ISO/IEC 27701:2025.....2

Introducción.....3

 0.1 Generalidades.....3

 0.2 Compatibilidad con otras normas de sistemas de gestión.....3

1 Objeto y campo de aplicación.....3

2. Referencias normativas.....4

3. Términos, definiciones y abreviaturas.....4

4. Contexto de la organización.....8

5. Liderazgo.....10

6. Planificación.....12

7. Soporte.....16

8. Operación.....19

9. Evaluación del desempeño.....21

ISO/IEC 27701:2025

Seguridad de la información, ciberseguridad y protección de la privacidad — Sistemas de gestión de la información de privacidad — Requisitos y directrices

Prefacio

La **ISO (Organización Internacional de Normalización)** y la **IEC (Comisión Electrotécnica Internacional)** conforman el sistema especializado de normalización a nivel mundial.

Los organismos nacionales miembros de la ISO o de la IEC participan en el desarrollo de las Normas Internacionales mediante comités técnicos establecidos para tratar campos específicos de actividad técnica.

La ISO y la IEC colaboran en ámbitos de interés común. Otras organizaciones internacionales, gubernamentales y no gubernamentales, también participan en estos trabajos.

Los procedimientos utilizados para desarrollar este documento y los previstos para su mantenimiento están descritos en las **Directivas ISO/IEC, Parte 1**.

En particular, deben observarse los distintos criterios de aprobación requeridos para cada tipo de documento.

Este documento se redactó de acuerdo con las reglas editoriales establecidas en las **Directivas ISO/IEC, Parte 2** (véase www.iso.org/directives o www.iec.ch/members_experts/refdocs).

La ISO y la IEC llaman la atención sobre la posibilidad de que la implementación de este documento pueda implicar el uso de una o más patentes.

No asumen responsabilidad alguna por la identificación o validez de tales derechos de patente.

Cualquier nombre comercial utilizado en este documento se incluye únicamente por conveniencia del usuario y no constituye respaldo alguno.

Este documento fue elaborado por el **Comité Técnico Conjunto ISO/IEC JTC 1, Tecnología de la información**. Subcomité **SC 27, Seguridad de la información, ciberseguridad y protección de la privacidad**, en colaboración con el **Comité Técnico CEN/CLC/JTC 13, Ciberseguridad y protección de datos** del Comité Europeo de Normalización (CEN), conforme al Acuerdo de Cooperación Técnica ISO-CEN (Acuerdo de Viena).

Esta **segunda edición (2025)** anula y reemplaza a la **primera edición (ISO/IEC 27701:2019)**, que se ha revisado técnicamente.

Los principales cambios son los siguientes:

- El documento se ha reescrito como una norma independiente de sistema de gestión.
-

Introducción

0.1 Generalidades

Casi todas las organizaciones procesan **información personal identificable (PII)**. La cantidad y los tipos de PII procesados aumentan continuamente, al igual que los casos en que una organización necesita cooperar con otras en dicho tratamiento.

La **protección de la privacidad** en este contexto es una **necesidad social**, además de un requisito legal en múltiples jurisdicciones.

Este documento incluye mapeos con:

- El marco y los principios de privacidad definidos en **ISO/IEC 29100**;
- **ISO/IEC 27018**;
- **ISO/IEC 29151**; y
- el **Reglamento General de Protección de Datos (GDPR)** de la Unión Europea.

(Nota: estos mapeos pueden adaptarse a los requisitos legales locales.)

El documento puede ser utilizado tanto por **controladores de PII** (incluidos los controladores conjuntos) como por **procesadores de PII** (incluidos los subcontratados).

Cumplir con los requisitos de esta norma permite a una organización generar **evidencia verificable** de cómo gestiona el tratamiento de la PII, facilitando acuerdos con socios comerciales e incrementando la confianza con otras partes interesadas.

El uso de esta norma también permite una **verificación independiente** de dichas evidencias.

0.2 Compatibilidad con otras normas de sistemas de gestión

Este documento utiliza el marco desarrollado por ISO para mejorar la **alineación entre las normas de sistemas de gestión**. Permite a las organizaciones **integrar o alinear su sistema de gestión de la privacidad (PIMS)** con los requisitos de otras normas, en especial con el **sistema de gestión de seguridad de la información** especificado en **ISO/IEC 27001**.

1 Objeto y campo de aplicación

Este documento especifica los **requisitos para establecer, implementar, mantener y mejorar continuamente un Sistema de Gestión de la Información de Privacidad (PIMS)**. También proporciona **orientaciones** para asistir en la implementación de estos requisitos.

Está destinado a **controladores y procesadores de PII** responsables del tratamiento de dicha información.

Es aplicable a **todo tipo y tamaño de organización**, incluyendo empresas públicas y privadas, entidades gubernamentales y organizaciones sin fines de lucro.

2. Referencias normativas

Los siguientes documentos se citan de tal modo que, en su totalidad o en parte, constituyen requisitos de este documento.

Para las referencias con fecha, solo se aplica la edición citada; para las referencias sin fecha, se aplicará la edición más reciente (incluyendo sus enmiendas).

- **ISO/IEC 29100**, *Tecnología de la información — Técnicas de seguridad — Marco de privacidad*.
-

3. Términos, definiciones y abreviaturas

Para los fines de este documento, se aplican los términos y definiciones dados en **ISO/IEC 29100**, junto con los siguientes.

ISO y la IEC mantienen bases de datos terminológicas para su uso en normalización en las siguientes direcciones:

- Plataforma de navegación en línea de ISO: <https://www.iso.org/obp>
 - Electropedia de IEC: <https://www.electropedia.org/>
-

3.1 Organización

Persona o grupo de personas que tiene sus propias funciones, responsabilidades, autoridades y relaciones para alcanzar sus objetivos.

Nota 1: El concepto de organización incluye, entre otros, empresario individual, empresa, corporación, sociedad, autoridad, asociación, fundación o institución, ya sea pública o privada.

Nota 2: Si la organización forma parte de una entidad mayor, el término "organización" se refiere solo a la parte incluida dentro del alcance del sistema de gestión de privacidad (ver 3.23).

3.2 Parte interesada

Persona u organización que puede afectar, ser afectada o percibirse como afectada por una decisión o actividad.

3.3 Alta dirección

Persona o grupo de personas que dirige y controla una organización en el nivel más alto.

Nota 1: Tiene poder para delegar autoridad y asignar recursos.

Nota 2: Si el sistema de gestión abarca solo parte de la organización, "alta dirección" se refiere a quienes dirigen y controlan esa parte.

3.4 Sistema de gestión

Conjunto de elementos interrelacionados o que interactúan en una organización para establecer políticas, objetivos y procesos para alcanzarlos.

Notas:

1. Un sistema de gestión puede abordar una o varias disciplinas.
 2. Incluye estructura, roles, planificación y operación.
-

3.5 Política

Intenciones y dirección de una organización, expresadas formalmente por la alta dirección.

3.6 Objetivo

Resultado a alcanzar.

Puede ser estratégico, táctico u operativo, y referirse a diversas disciplinas (finanzas, seguridad, salud, medio ambiente).

En el contexto del PIMS, los **objetivos de privacidad** son establecidos por la organización, en coherencia con su política de privacidad.

3.7 Riesgo

Efecto de la incertidumbre.

Un efecto es una desviación de lo esperado (positiva o negativa).

La incertidumbre es la falta parcial o total de información sobre un evento, sus consecuencias o probabilidad.

El riesgo suele expresarse como una combinación de **consecuencias** y **probabilidad**.

3.8 Proceso

Conjunto de actividades interrelacionadas que utilizan o transforman insumos para entregar un resultado.

3.9 Competencia

Capacidad para aplicar conocimientos y habilidades para lograr resultados previstos.

3.10 Información documentada

Información que la organización debe **controlar y mantener**, y el medio en que se contiene. Puede incluir:

- el sistema de gestión y sus procesos,
- documentación operativa,

- y registros como evidencia de resultados.
-

3.11 Desempeño

Resultado medible, cuantitativo o cualitativo, relacionado con la gestión de actividades, procesos, productos, servicios o sistemas.

3.12 Mejora continua

Actividad recurrente para **mejorar el desempeño**.

3.13 Eficacia

Grado en que se logran las actividades y resultados planificados.

3.14 Requisito

Necesidad o expectativa establecida, generalmente implícita u obligatoria.

Un requisito **especificado** es aquel que está declarado en la información documentada.

3.15 Conformidad

Cumplimiento de un requisito.

3.16 No conformidad

Incumplimiento de un requisito.

3.17 Acción correctiva

Acción para eliminar la(s) causa(s) de una no conformidad y prevenir su recurrencia.

3.18 Auditoría

Proceso sistemático e independiente para obtener evidencia y evaluarla objetivamente, con el fin de determinar el grado de cumplimiento de los criterios de auditoría.

Puede ser interna (primera parte) o externa (segunda o tercera parte).

3.19 Medición

Proceso para determinar un valor.

3.20 Monitoreo

Determinación del estado de un sistema, proceso o actividad.

3.21 Controlador conjunto de PII

Controlador de información personal que determina los fines y medios del tratamiento junto con otros controladores.

3.22 Cliente

Persona u organización que puede o recibe un producto o servicio.

Ejemplos: consumidor, usuario final, beneficiario o comprador.

Puede ser interno o externo.

3.23 Sistema de gestión de información de privacidad (PIMS)

Sistema de gestión que aborda la protección de la privacidad como puede verse afectada por el tratamiento de información personal.

3.24 Programa de seguridad de la información

Conjunto de políticas, objetivos y procesos diseñados para gestionar los riesgos de seguridad de la información y garantizar la **confidencialidad, integridad y disponibilidad**.

3.25 Declaración de aplicabilidad (SoA)

Documentación que incluye todos los controles necesarios y la justificación para su inclusión o exclusión.

4. Contexto de la organización

4.1 Comprensión de la organización y su contexto

La organización deberá **determinar los factores externos e internos** que sean relevantes para su propósito y que afecten su capacidad para lograr los resultados previstos de su **Sistema de Gestión de la Información de Privacidad (PIMS)**.

La organización deberá determinar si el **cambio climático** constituye un factor relevante.

Asimismo, deberá determinar si actúa como **controlador de información personal identificable (PII)** — incluido controlador conjunto— o como **procesador de PII**.

La organización deberá identificar los **temas internos y externos relevantes a su contexto** que puedan afectar el cumplimiento de los resultados esperados del PIMS.

NOTA 1:

Los temas internos y externos pueden incluir, entre otros:

- Legislación de privacidad aplicable;
- Regulaciones pertinentes;
- Decisiones judiciales relevantes;
- Políticas, normas y procedimientos internos de gobierno corporativo;
- Decisiones administrativas;
- Requisitos contractuales aplicables.

Cuando la organización actúe en **ambos roles** (controlador y procesador de PII), deberá determinar cada uno por separado, con su propio conjunto de controles.

NOTA 2:

El rol de la organización puede variar en cada caso particular de tratamiento de PII, dependiendo de quién determine los fines y medios del procesamiento.

4.2 Comprensión de las necesidades y expectativas de las partes interesadas

La organización deberá determinar:

- las **partes interesadas** relevantes para el sistema de gestión de privacidad;
- los **requisitos de dichas partes interesadas**; y
- **cuáles de esos requisitos** se abordarán a través del sistema de gestión de privacidad.

NOTA 1:

Las partes interesadas relevantes pueden tener requisitos relacionados con el **cambio climático** (por ejemplo, sostenibilidad o impacto ambiental del procesamiento de datos).

La organización deberá incluir entre sus partes interesadas a todas aquellas con **intereses o responsabilidades asociadas al tratamiento de PII**, incluidos los **titulares de los datos (PII principals)**.

NOTA 2:

Otras partes interesadas pueden incluir clientes, autoridades de control, otros controladores de PII, procesadores y sus subcontratistas.

Dependiendo del rol de la organización, el término “cliente” podrá interpretarse como:

- a) Una organización que tiene un contrato con un **controlador de PII** (por ejemplo, el cliente del controlador);
- b) Un **controlador** que contrata a un **procesador de PII** (por ejemplo, el cliente del procesador); o
- c) Un **procesador de PII** que contrata a un **subcontratista** (por ejemplo, el cliente del procesador subcontratado).

NOTA 3:

Una persona individual cuya información personal es tratada en el marco de una relación comercial (consumidor, empleado, proveedor, visitante, etc.) se denomina **títular de PII (PII principal)**.

NOTA 4:

Los requisitos relevantes al tratamiento de PII pueden surgir de **obligaciones legales o regulatorias, contratos, o objetivos organizacionales autoimpuestos**.

Los **principios de privacidad** definidos en **ISO/IEC 29100** ofrecen orientación adicional.

NOTA 5:

Para demostrar conformidad, algunas partes interesadas pueden requerir que la organización cumpla con **normas específicas** (por ejemplo, esta norma) y que dicha conformidad sea **auditada de manera independiente**.

4.3 Determinación del alcance del Sistema de Gestión de Privacidad

La organización deberá **definir los límites y la aplicabilidad** del sistema de gestión de privacidad a fin de establecer su **alcance formal**.

Al determinar dicho alcance, deberá considerar:

- los temas internos y externos mencionados en el punto 4.1, y
- los requisitos de las partes interesadas definidos en el punto 4.2.

El **alcance del sistema** deberá estar disponible como **información documentada**, e **incluir expresamente el tratamiento de la información personal (PII)**.

4.4 Sistema de Gestión de la Información de Privacidad (PIMS)

La organización deberá **establecer, implementar, mantener y mejorar continuamente** un sistema de gestión de privacidad, incluyendo los **procesos necesarios y sus interacciones**, de acuerdo con los requisitos de esta norma.

5. Liderazgo

5.1 Liderazgo y compromiso

La **alta dirección** deberá demostrar liderazgo y compromiso respecto al Sistema de Gestión de la Información de Privacidad (PIMS) mediante:

- Es importante que la **política de privacidad** (ver 5.2) y los **objetivos de privacidad** (ver 6.2) se definan y estén alineados con la **dirección estratégica** de la organización.
- Integrar los requisitos del PIMS dentro de los **procesos de negocio** de la organización.
- Garantizar que los **recursos necesarios** para el sistema de gestión de privacidad estén disponibles.
- Comunicar la **importancia de una gestión eficaz de la privacidad** y del cumplimiento de los requisitos del sistema.
- Garantizar que el sistema de gestión de privacidad logre los resultados esperados.
- **Dirigir y apoyar** a las personas para que contribuyan a la eficacia del sistema.
- **Promover la mejora continua.**
- Respalda a otros roles relevantes dentro de la organización para que demuestren liderazgo en las áreas bajo su responsabilidad.

NOTA:

La referencia a “negocio” en este documento debe interpretarse en sentido amplio, abarcando las actividades esenciales para el propósito y la existencia de la organización.

5.2 Política de privacidad

La alta dirección deberá **establecer una política de privacidad** que:

- a) Sea **apropiada al propósito y contexto** de la organización.
- b) Proporcione un **marco de referencia** para establecer los **objetivos de privacidad**.
- c) Incluya un **compromiso de cumplimiento** con los requisitos aplicables (legales, regulatorios, contractuales o de partes interesadas).
- d) Incluya un **compromiso con la mejora continua** del sistema de gestión de privacidad.

La política de privacidad deberá:

- Estar **disponible como información documentada**.
- Comunicarse **internamente** dentro de la organización.
- Estar **disponible para las partes interesadas** externas, según corresponda.

Recomendación práctica:

La política debe estar publicada en medios accesibles (por ejemplo, intranet corporativa, portal web o políticas de proveedor) y revisarse al menos una vez por año o ante cambios significativos en el marco normativo o en las actividades de tratamiento de PII.

5.3 Roles, responsabilidades y autoridades

La **alta dirección** deberá asegurar que las **responsabilidades y autoridades** asociadas a los roles relevantes estén **asignadas, documentadas y comunicadas** dentro de la organización.

Deberá asignarse explícitamente la **responsabilidad y autoridad** para:

- a) Garantizar que el sistema de gestión de privacidad **cumpla con los requisitos** establecidos en esta norma.
- b) **Reportar a la alta dirección** sobre el desempeño del sistema de gestión de privacidad, incluyendo resultados de auditorías, revisiones y planes de mejora.

Ejemplo práctico:

En una estructura organizacional típica:

- El **Chief Privacy Officer (CPO)** o **Responsable de Protección de Datos (DPO)** asume la responsabilidad operativa del PIMS.
- La **Alta Dirección** aprueba la política de privacidad, los objetivos estratégicos y los recursos.
- Los **dueños de proceso** (procesamiento, seguridad, RRHH, TI, marketing, proveedores) mantienen controles específicos y reportan incidentes o desviaciones.

NOTA:

Estas responsabilidades pueden formalizarse en un **organigrama funcional** o en una **matriz RACI**, que identifique los responsables (Responsible), aprobadores (Accountable), consultados (Consulted) e informados (Informed).

6. Planificación

6.1 Acciones para abordar riesgos y oportunidades

6.1.1 Generalidades

Al planificar el Sistema de Gestión de la Información de Privacidad (PIMS), la organización deberá considerar:

- los **factores internos y externos** identificados en el punto 4.1, y
- los **requisitos de las partes interesadas** definidos en el punto 4.2,

y determinar los **riesgos y oportunidades** que deben abordarse con el fin de:

- Hay que asegurar que el PIMS pueda **lograr los resultados previstos**.
- **Prevenir o reducir** los efectos no deseados.
- **Mejorar continuamente** el sistema.

La organización deberá planificar:

- a) Las **acciones** necesarias para abordar los riesgos y oportunidades identificados.
 - b) Cómo:
 - **Integrar e implementar** dichas acciones dentro de los procesos del PIMS.
 - **Evaluar la eficacia** de las acciones ejecutadas.
-

6.1.2 Evaluación de riesgos de privacidad (Privacy Risk Assessment)

La organización deberá **definir y aplicar un proceso de evaluación de riesgos de privacidad**, que cumpla con lo siguiente:

- a) **Establecer y mantener criterios de riesgo de privacidad**, que incluyan:
 1. Los **criterios de aceptación del riesgo**; y
 2. Los **criterios para realizar las evaluaciones de riesgo**.
- b) Hay que asegurar que las evaluaciones repetidas de riesgo de privacidad produzcan **resultados consistentes, válidos y comparables**.
- c) Identificar los **riesgos de privacidad**:
 1. Relacionados con la protección de la privacidad y los riesgos de seguridad de la información dentro del alcance del PIMS.
 2. Identificar los **propietarios de riesgo** correspondientes.
- d) Analizar los riesgos de privacidad, evaluando:
 1. Las **consecuencias potenciales** tanto para la organización como para los **titulares de los datos (PII principales)** si los riesgos se materializan.
 2. La **probabilidad realista de ocurrencia** de dichos riesgos.
 3. El **nivel de riesgo** resultante.
- e) Evaluar los riesgos de privacidad mediante:
 1. La comparación de los resultados del análisis de riesgos con los **criterios establecidos** en el punto a).

2. La **priorización** de los riesgos analizados para su tratamiento.

La organización deberá **mantener información documentada** sobre el proceso de evaluación de riesgos de privacidad.

NOTA:

Para información adicional sobre la metodología de evaluación de riesgos de privacidad, puede consultarse **ISO/IEC 27557**, que detalla el enfoque de riesgo basado en PII.

6.1.3 Tratamiento de riesgos de privacidad (Privacy Risk Treatment)

La organización deberá **definir y aplicar un proceso de tratamiento de riesgos de privacidad** relacionados con el procesamiento de PII, incluyendo los riesgos que afectan a los titulares de los datos, y la seguridad de dicha información.

El proceso deberá incluir:

- a) La **selección de opciones de tratamiento** de riesgo adecuadas, basadas en los resultados del análisis previo.
- b) La **determinación de todos los controles necesarios** para implementar las opciones seleccionadas.

Las organizaciones pueden diseñar controles propios o identificar controles provenientes de otras fuentes.

- c) La **identificación y documentación del programa de seguridad de la información** implementado por la organización, incluyendo los controles de seguridad apropiados.

Este programa, como mínimo, deberá abarcar:

- Gestión de riesgos de seguridad de la información;
- Políticas de seguridad de la información;
- Organización de la seguridad;
- Seguridad en recursos humanos;
- Gestión de activos;
- Control de acceso;
- Seguridad en operaciones;
- Gestión de redes;
- Seguridad en el desarrollo de software;
- Gestión de proveedores;
- Gestión de incidentes;
- Continuidad de la seguridad de la información;
- Revisión y auditoría de seguridad;
- Cifrado y gestión de claves criptográficas;
- Seguridad física y ambiental.

NOTA 1:

La norma **ISO/IEC 27002** puede utilizarse como referencia para identificar posibles controles de seguridad de la información.

Si el programa de seguridad se basa en **ISO/IEC 27001**, se recomienda consultar 27002 para verificar que no se omitan controles necesarios.

- d) **Comparar los controles determinados** en los puntos anteriores con los listados en el **Anexo A** de esta norma, verificando que no se omitan controles necesarios.

NOTA 2:

El Anexo A incluye una lista de posibles controles de privacidad, no exhaustiva; pueden añadirse controles adicionales si es necesario.

- e) Elaborar una **Declaración de Aplicabilidad (SoA)** que incluya:
- Los controles necesarios definidos;
 - La justificación de su inclusión;
 - Si cada control está implementado o no;
 - La justificación para excluir cualquier control del Anexo A.

No es obligatorio incluir todos los controles del Anexo A.

Pueden excluirse aquellos que no sean aplicables según el análisis de riesgo o los requisitos legales específicos.

- f) Formular un **Plan de Tratamiento de Riesgos de Privacidad**, con las acciones, responsables, plazos y recursos necesarios.
- g) Obtener la **aprobación de los propietarios de riesgo** sobre el plan y la **aceptación de los riesgos residuales**.
- h) Considerar la orientación del **Anexo B** para la implementación de los controles seleccionados.

La organización deberá **mantener información documentada** sobre todo el proceso de tratamiento de riesgos.

6.2 Objetivos de privacidad y planificación para lograrlos

La organización deberá establecer **objetivos de privacidad** en los niveles y funciones pertinentes.

Los objetivos deberán:

- a) Ser **coherentes con la política de privacidad** (ver 5.2).
- b) Ser **medibles**, siempre que sea posible.
- c) Tener en cuenta los **requisitos aplicables**.
- d) Ser **monitoreados y evaluados**.
- e) Comunicarse dentro de la organización.
- f) Actualizarse cuando corresponda.
- g) Estar **disponibles como información documentada**.

Al planificar cómo alcanzar los objetivos de privacidad, la organización deberá definir:

- Qué se va a hacer;
- Qué **recursos** se requerirán;
- **Quién** será responsable;
- **Cuando** se completará;
- Cómo se evaluarán los **resultados obtenidos**.

6.3 Planificación de los cambios

Cuando la organización determine la necesidad de realizar cambios en el sistema de gestión de privacidad, estos deberán ejecutarse de manera **planificada y controlada**, garantizando la continuidad y la integridad del sistema.

7. Soporte

7.1 Recursos

La organización deberá **determinar y proporcionar los recursos necesarios** para establecer, implementar, mantener y mejorar de forma continua el **Sistema de Gestión de la Información de Privacidad (PIMS)**.

Estos recursos deberán incluir:

- personal con competencias adecuadas,
 - infraestructura tecnológica y documental,
 - y apoyo financiero suficiente para garantizar la eficacia del sistema.
-

7.2 Competencia

La organización deberá:

- a) Determinar las **competencias necesarias** de las personas que realicen trabajos bajo su control que afecten el desempeño del PIMS.
- b) Asegurar que dichas personas sean **competentes**, basándose en la **educación, formación o experiencia** apropiada.
- c) Cuando sea aplicable, **adoptar acciones para adquirir la competencia necesaria** (por ejemplo, capacitación, mentoría, reubicación o contratación de personal especializado).
- d) **Evaluar la eficacia** de las acciones tomadas para asegurar que se alcancen los niveles de competencia requeridos.

La organización deberá **mantener información documentada** como evidencia de las competencias del personal (por ejemplo, CV, certificados, evaluaciones de desempeño o registros de capacitación).

NOTA:

Entre las acciones posibles se incluyen:

- formación formal en seguridad y privacidad,
 - mentoría o coaching interno,
 - o contratación de especialistas en protección de datos o Compliance.
-

7.3 Concientización

Las personas que trabajen bajo el control de la organización deberán ser **conscientes de:**

- La **política de privacidad** (ver 5.2).
- Su **contribución a la eficacia** del sistema de gestión de privacidad.
- Los **beneficios** de una buena gestión de la privacidad.
- Las **consecuencias de no cumplir** con los requisitos del sistema o con las normas aplicables.

Recomendación práctica:

Se deben realizar **campañas periódicas de concientización**, simulaciones o entrenamientos por rol (por ejemplo, empleados, desarrolladores, marketing, RRHH, proveedores) para mantener la cultura de privacidad activa.

7.4 Comunicación

La organización deberá **determinar las comunicaciones internas y externas** relevantes para el sistema de gestión de privacidad, incluyendo:

- a) **Qué** se comunicará.
- b) **Cuando** se comunicará.
- c) **Con quién** se comunicará.
- d) **Cómo** se comunicará (método, canal o formato).

Ejemplos:

- Comunicación interna: reportes de incidentes, nuevas políticas, capacitaciones, resultados de auditoría.
 - Comunicación externa: respuesta a autoridades de control, titulares de datos, proveedores o clientes.
-

7.5 Información documentada

7.5.1 Generalidades

El sistema de gestión de privacidad deberá incluir:

- a) La **información documentada requerida por esta norma**.
- b) La información adicional que la organización determine como **necesaria para garantizar la eficacia** del sistema.

NOTA:

El volumen y tipo de documentación dependerá de:

- el tamaño y la naturaleza de la organización;
 - la complejidad de los procesos;
 - la competencia y madurez del personal.
-

7.5.2 Creación y actualización de la información documentada

Al crear o actualizar información documentada, la organización deberá asegurar que se mantenga la **identificación y trazabilidad**, incluyendo:

- **Título, fecha, autor y número de referencia.**
 - **Formato y medio** (por ejemplo, idioma, versión de software, formato electrónico o papel).
 - **Revisión y aprobación formal** antes de su emisión, garantizando su idoneidad y adecuación.
-

7.5.3 Control de la información documentada

La información documentada requerida por el PIMS y por esta norma deberá **controlarse** para asegurar que:

- a) Esté **disponible y sea adecuada para su uso** donde y cuando se la necesite.
- b) Esté **protegida adecuadamente** frente a pérdida de confidencialidad, uso indebido o pérdida de integridad.

La organización deberá establecer controles para las siguientes actividades (según corresponda):

- **Distribución, acceso, recuperación y uso.**
- **Almacenamiento y preservación**, garantizando la **legibilidad** a lo largo del tiempo.
- **Control de cambios y versiones.**
- **Retención y disposición final** de documentos y registros.

La información documentada **de origen externo**, que la organización considere necesaria para la planificación y operación del sistema, deberá ser **identificada y controlada** adecuadamente.

NOTA:

El acceso puede implicar solo el permiso de **visualización**, o también la **autorización para modificar** el documento, dependiendo del rol y nivel de autoridad del usuario.

8. Operación

8.1 Planificación y control operacional

La organización deberá **planificar, implementar y controlar los procesos necesarios** para cumplir con los requisitos establecidos y ejecutar las acciones definidas en el **punto 6 (Planificación)**, mediante:

- el **establecimiento de criterios** para la correcta ejecución de los procesos; y
- la **implementación de controles** sobre dichos procesos conforme a los criterios definidos.

Deberá mantenerse **información documentada** suficiente para garantizar la **confianza en que los procesos se realizan conforme a lo planificado**.

La organización deberá **controlar los cambios planificados** y **revisar las consecuencias de los cambios no previstos**, tomando las acciones necesarias para **mitigar los efectos adversos**.

Asimismo, deberá asegurarse de que los **procesos, productos o servicios externos** que sean relevantes para el PIMS estén **adecuadamente controlados** mediante políticas o acuerdos (por ejemplo, contratos de confidencialidad, cláusulas de privacidad o acuerdos de nivel de servicio – SLA).

8.2 Evaluación de riesgos de privacidad (Privacy Risk Assessment)

La organización deberá realizar **evaluaciones de riesgos de privacidad** en intervalos planificados o **cuando se propongan o produzcan cambios significativos**, considerando los criterios establecidos en el **punto 6.1.2 (a)**.

Deberá **mantener información documentada** sobre los **resultados de dichas evaluaciones** y las acciones derivadas de las mismas.

Ejemplo práctico:

Una evaluación adicional deberá efectuarse al implementar nuevas tecnologías, realizar cambios en la arquitectura de datos, migrar información a la nube, o iniciar nuevas actividades de tratamiento (por ejemplo, biometría, analítica, geolocalización, etc.).

8.3 Tratamiento de riesgos de privacidad (Privacy Risk Treatment)

La organización deberá **implementar el plan de tratamiento de riesgos de privacidad** definido conforme al **punto 6.1.3**.

También deberá **mantener evidencia documentada** de los resultados obtenidos en la aplicación de dicho plan, incluyendo:

- los controles implementados,
- las medidas correctivas adoptadas, y
- el estado de los riesgos residuales.

NOTA:

La evidencia puede incluir matrices de riesgo actualizadas, registros de aceptación de riesgo firmados por los responsables, reportes de auditoría interna y documentación de verificación de controles (por ejemplo, logs de acceso, registros de capacitación o reportes de vulnerabilidades corregidas).

Resumen operativo

El capítulo 8 establece que el **PIMS debe operar como un ciclo controlado y verificable**, asegurando que los procesos cumplan con los criterios definidos, que los riesgos de privacidad sean **evaluados y tratados continuamente**, y que todas las acciones estén **documentadas y demostrables** ante auditorías o autoridades de control.

9. Evaluación del desempeño

9.1 Monitoreo, medición, análisis y evaluación

La organización deberá determinar:

- **Qué** aspectos del sistema de gestión de privacidad necesitan ser monitoreados y medidos.
- **Los métodos** de monitoreo, medición, análisis y evaluación que aseguren resultados válidos.
- **Cuándo** se deben realizar las actividades de monitoreo y medición.
- **Cuándo** se analizarán y evaluarán los resultados obtenidos.

Deberá conservarse **información documentada como evidencia** de los resultados de dichas actividades.

La organización deberá **evaluar el desempeño en privacidad** y la **eficacia del sistema de gestión de privacidad (PIMS)**.

Ejemplo de métricas típicas:

- Cantidad de incidentes de privacidad reportados y resueltos.
 - Tiempo promedio de respuesta ante incidentes.
 - Nivel de cumplimiento en auditorías internas.
 - Porcentaje de empleados capacitados en protección de datos.
 - Evaluación de satisfacción de titulares de datos o partes interesadas.
-

9.2 Auditoría interna

9.2.1 Generalidades

La organización deberá realizar **auditorías internas en intervalos planificados** para verificar si el sistema de gestión de privacidad:

a) **Cumple con:**

- Los requisitos propios de la organización para su sistema de gestión de privacidad.
- Los requisitos establecidos por la norma ISO/IEC 27701.

b) Está siendo **implementado y mantenido de manera eficaz**.

9.2.2 Programa de auditoría interna

La organización deberá **planificar, establecer, implementar y mantener uno o más programas de auditoría**, que incluyan:

- La **frecuencia** de las auditorías.
- Los **métodos y criterios** de auditoría.
- Las **responsabilidades** y el alcance.
- Los **requisitos de planificación y reporte de resultados**.

Al establecer el programa de auditoría, la organización deberá considerar:

- La **importancia de los procesos auditados**.
- Los **resultados de auditorías anteriores**.

La organización deberá:

- Definir los **objetivos, criterios y alcance** para cada auditoría.
- Seleccionar **auditores competentes e independientes**, asegurando la **imparcialidad** del proceso.
- Asegurar que los **resultados de las auditorías** sean comunicados oportunamente a los **gestores responsables**.

Deberá mantenerse **información documentada** como evidencia de la **ejecución del programa de auditoría** y de los **resultados obtenidos**.

Recomendación

práctica:

Las auditorías internas deberían cubrir los **controles del Anexo A** y los **procesos de riesgo y cumplimiento**, alternando las áreas críticas (por ejemplo, RRHH, proveedores, desarrollo, marketing, seguridad de la red, etc.). Pueden emplearse **listas de verificación ISO 27001/27701** o auditorías combinadas de SGSI + PIMS.

9.3 Revisión por la dirección

9.3.1 Generalidades

La **alta dirección** deberá **revisar el sistema de gestión de privacidad** en intervalos planificados, para garantizar su **pertinencia, adecuación y eficacia continua**.

9.3.2 Entradas para la revisión por la dirección

La revisión deberá incluir, como mínimo:

- El **estado de las acciones** resultantes de revisiones anteriores.
- Los **cambios en factores internos y externos** que sean relevantes para el PIMS.
- Los **cambios en las necesidades y expectativas** de las partes interesadas.
- Información sobre el **desempeño del PIMS**, incluyendo tendencias en:
 - No conformidades y acciones correctivas.
 - Resultados de monitoreo y medición.
 - Resultados de auditorías internas.
- Oportunidades de mejora continua.**

Ejemplo de fuentes de información para la revisión:

- Resultados de evaluaciones de riesgo.
- Reportes de incidentes o fugas de datos.
- Indicadores de cumplimiento legal (GDPR, Ley 25.326, etc.).
- Retroalimentación de clientes y autoridades de control.
- Progreso de los objetivos de privacidad definidos en el punto 6.2.

9.3.3 Resultados de la revisión por la dirección

Los resultados de la revisión deberán incluir decisiones relacionadas con:

- Las **oportunidades de mejora continua**.
- Cualquier **necesidad de cambios** en el sistema de gestión de privacidad, sus políticas u objetivos.

La organización deberá **mantener información documentada** como evidencia de los **resultados de la revisión por la dirección**.

Recomendación:

Registrar la revisión en un **Acta de Revisión de la Dirección**, con fecha, asistentes, puntos tratados, decisiones, responsables y plazos, conforme al ciclo PDCA (Plan-Do-Check-Act).

10. Mejora

10.1 Mejora continua

La organización deberá **mejorar de manera continua** la **pertinencia, adecuación y eficacia** del **Sistema de Gestión de la Información de Privacidad (PIMS)**.

Esto implica revisar sistemáticamente los resultados de las auditorías internas, las revisiones por la dirección, los incidentes de privacidad, las no conformidades y los indicadores de desempeño, con el fin de **identificar oportunidades de optimización y reforzar los controles existentes**.

Ejemplos de mejora continua:

- Automatización de procesos de gestión de consentimientos.
- Integración de herramientas de Data Loss Prevention (DLP).
- Implementación de dashboards de métricas de privacidad.
- Revisión y actualización de políticas y cláusulas contractuales con terceros.

10.2 No conformidades y acciones correctivas

Cuando ocurra una **no conformidad**, la organización deberá:

a) **Reaccionar ante la no conformidad**, y, según corresponda:

- Adoptar medidas para **controlarla y corregirla**.
- Abordar las **consecuencias** derivadas de la misma.

b) Evaluar la necesidad de **acciones para eliminar la(s) causa(s)** de la no conformidad, de modo que no se repita ni ocurra en otros contextos, mediante:

- La **revisión de la no conformidad**.
- La **determinación de sus causas raíz**.
- La **verificación de si existen no conformidades similares** o potencialmente recurrentes.

- c) **Implementar las acciones necesarias.**
- d) **Revisar la eficacia** de las acciones correctivas tomadas.
- e) Realizar los **ajustes necesarios** en el sistema de gestión de privacidad.

Las acciones correctivas deberán ser **proporcionales a la magnitud y el impacto** de la no conformidad detectada.

La organización deberá mantener **información documentada** como evidencia de:

- La **naturaleza de las no conformidades** y las **acciones adoptadas**.
- Los **resultados y eficacia** de las acciones correctivas.

Ejemplo práctico:

- Se detecta un incidente de acceso indebido a información personal.
 - Acción inmediata: bloqueo de cuentas y notificación al responsable de seguridad.
 - Acción correctiva: revisión de políticas de control de acceso y refuerzo de autenticación multifactor.
 - Acción preventiva: capacitación específica y auditoría de permisos trimestral.

Resumen del capítulo 10

El punto 10 refuerza el principio de **ciclo PDCA (Plan-Do-Check-Act)** aplicado a la privacidad, estableciendo que toda desviación o incidente debe ser analizado, corregido, documentado y utilizado como insumo para la mejora continua del sistema.

Anexo A (Normativo)

Objetivos de control y controles de referencia del PIMS para Controladores y Procesadores de Información Personal Identificable (PII)

Este anexo está destinado a ser utilizado por organizaciones que actúan como **controladores de PII**, **procesadores de PII**, o **ambos**.

No es necesario incluir todos los objetivos de control y controles listados en este anexo dentro de la implementación del PIMS.

La **Declaración de Aplicabilidad (SoA)** deberá incluir una **justificación** para la exclusión de cualquier control.

Las razones pueden incluir que el control **no sea necesario según la evaluación de riesgos**, o **no sea requerido por la normativa aplicable** (o esté exceptuado bajo ella).

- **Tabla A.1:** Controles aplicables a **Controladores de PII**.
- **Tabla A.2:** Controles aplicables a **Procesadores de PII**.
- **Tabla A.3:** Controles de **seguridad de la información** aplicables a ambos.

NOTA:

Las referencias en la columna “Referencia del control” de las Tablas A.1, A.2 y A.3 corresponden a los números de cláusula equivalentes en el **Anexo B**, donde se encuentra la guía detallada para su implementación (por ejemplo, la guía para el control A.1.2.2 se encuentra en B.1.2.2).

Tabla A.1 — Objetivos de control y controles para Controladores de PII

Condiciones para la recolección y procesamiento

Objetivo:

Demostrar que el procesamiento de información personal es **lícito**, con **base legal** conforme a las jurisdicciones aplicables, y con **propósitos definidos y legítimos**.

A.1.2.2 – Identificar y documentar el propósito
La organización deberá identificar y documentar los **propósitos específicos** para los cuales la PII será procesada.

A.1.2.3 – Identificar la base legal
La organización deberá determinar, documentar y ser capaz de **demostrar el cumplimiento** con la base legal aplicable para el procesamiento de PII.

A.1.2.4 – Determinar cuándo y cómo se obtiene el consentimiento
La organización deberá definir y documentar el **proceso por el cual puede demostrar si, cuándo y cómo obtuvo el consentimiento** de los titulares de PII.

A.1.2.5 – Obtener y registrar el consentimiento
La organización deberá **obtener y registrar el consentimiento** de los titulares de PII de acuerdo con los procesos documentados.

Limitación y minimización del procesamiento

Objetivo:

Asegurar que el procesamiento de PII sea **relevante, proporcional y necesario** para los propósitos definidos.

A.1.4.3 - Limitar el procesamiento
La organización deberá limitar el procesamiento de PII a lo que sea **adecuado, pertinente y necesario** para los fines identificados

27701_2025 (en)

A.1.4.4 - Exactitud y calidad de los datos
La organización deberá asegurar y documentar que la PII sea **exacta, completa y actualizada** según lo necesario para los fines del tratamiento, durante todo su ciclo de vida.

A.1.4.5 - Objetivos de minimización de PII
La organización deberá **definir y documentar objetivos de minimización de datos** y los mecanismos (como desidentificación o anonimización) utilizados para cumplirlos.

A.1.4.6 - Desidentificación o eliminación de PII al final del tratamiento
La organización deberá **eliminar o transformar la PII** en una forma que no permita la identificación o reidentificación de los titulares, una vez que los fines originales ya no lo requieran.

A.1.4.7 - Archivos temporales
La organización deberá garantizar que los **archivos temporales creados durante el procesamiento de PII sean eliminados o destruidos** siguiendo procedimientos documentados y dentro de un período establecido.

A.1.4.8 - Retención
La organización **no deberá conservar la PII más tiempo del necesario** para los fines del tratamiento.

A.1.4.9 - Eliminación (disposición final)
La organización deberá tener **políticas, procedimientos o mecanismos documentados** para la eliminación segura de la PII.

A.1.4.10 - Controles de transmisión de PII
La organización deberá aplicar **controles adecuados** cuando la PII sea transmitida por redes de comunicación, para asegurar que los datos **lleguen a su destino previsto** sin alteraciones ni exposición no autorizada.

Compartición, transferencia y divulgación de PII

Objetivo:

Determinar y documentar **cuándo y cómo se comparte, transfiere o divulga PII** a terceros o a otras jurisdicciones, conforme a las obligaciones aplicables.

A.1.5.2 - Identificar la base para transferencias de PII entre jurisdicciones
La organización deberá **identificar y documentar** la base legal o contractual que respalde las transferencias de PII entre países o regiones.

A.1.5.3 - Países y organismos internacionales a los que puede transferirse la PII
La organización deberá **especificar y documentar** los países y organizaciones internacionales a los cuales la PII puede ser transferida.

- A.1.5.4 - Registros de transferencia de PII**
La organización deberá **mantener registros de las transferencias de PII** hacia o desde terceros y asegurar la **cooperación con esas partes** para atender futuras solicitudes relacionadas con los derechos de los titulares.
- A.1.5.5 - Registros de divulgación de PII a terceros**
La organización deberá **mantener registros de las divulgaciones de PII a terceros**, incluyendo **qué datos fueron divulgados, a quién y cuándo**

Tabla A.2 — Objetivos de control y controles para Procesadores de PII

Condiciones para la recolección y procesamiento

Objetivo:

Demostrar que el procesamiento de información personal (PII) se realiza conforme a bases legales aplicables, bajo acuerdo documentado con el controlador y para propósitos claramente definidos y legítimos.

A.2.2.2 - Acuerdo con el cliente (Customer Agreement)
El procesador deberá tener un **acuerdo contractual documentado** con el controlador de PII que defina el propósito, la naturaleza, el tipo de PII y las categorías de titulares de datos tratados, junto con las obligaciones de ambas partes.

A.2.2.3 - Propósitos de la organización (Organization's Purposes)
El procesador deberá **procesar la PII únicamente para los propósitos establecidos por el controlador**, salvo que exista autorización explícita o disposición legal que indique lo contrario.

A.2.2.4 - Uso en marketing o publicidad (Marketing and Advertising Use)
El procesador **no deberá usar PII** para fines de marketing o publicidad propios, excepto cuando esté **autorizado por el controlador** o por ley.

A.2.2.5 - Instrucciones que infringen la normativa (Infringing Instructions)
El procesador deberá **notificar al controlador** cuando una instrucción recibida **contradiga la legislación o reglamentación aplicable** sobre protección de datos personales.

A.2.2.6 - Obligaciones del cliente (Customer Obligations)
El procesador deberá definir los **mecanismos para cumplir con las obligaciones derivadas del contrato** con el controlador, asegurando que los procesos estén alineados con los requerimientos legales de privacidad y seguridad.

A.2.2.7 - Registros relacionados con el procesamiento de PII (Records Related to Processing)
El procesador deberá **mantener registros actualizados** de todas las actividades de procesamiento realizadas en nombre del controlador, incluyendo descripción de datos, fines, categorías y transferencias.

Cumplimiento de obligaciones hacia los titulares de PII

Objetivo:

Garantizar que el procesador respete los derechos de los titulares de PII y colabore con el controlador para cumplir sus obligaciones legales y regulatorias.

A.2.3.2 - Cumplir las obligaciones hacia los titulares de PII (Comply with Obligations to PII Principals)

El procesador deberá **asistir al controlador** en la gestión de los derechos de los titulares (por ejemplo, acceso, rectificación, eliminación, restricción o portabilidad), respondiendo dentro de los plazos legales establecidos.

Limitación del uso, retención y eliminación**Objetivo:**

Asegurar que la PII sea procesada, almacenada y eliminada según las instrucciones del controlador y conforme a las normas aplicables.

A.2.4.2 - Archivos temporales (Temporary Files)

El procesador deberá **eliminar o destruir archivos temporales** que contengan PII dentro de un período documentado y conforme a procedimientos establecidos.

A.2.4.3 - Devolución, transferencia o disposición de la PII (Return, Transfer or Disposal)

El procesador deberá **devolver, transferir o eliminar la PII** al finalizar el contrato o el tratamiento, según las instrucciones del controlador o conforme a los requisitos legales aplicables.

A.2.4.4 - Controles de transmisión de PII (PII Transmission Controls)

El procesador deberá aplicar **controles adecuados sobre la transmisión de PII**, para asegurar que los datos **alcancen su destino previsto** sin alteraciones ni accesos no autorizados.

Transferencia, divulgación y subcontratación**Objetivo:**

Garantizar que las transferencias o divulgaciones de PII a terceros sean seguras, documentadas y aprobadas por el controlador.

A.2.5.2 - Base para la transferencia de PII entre jurisdicciones (Basis for PII Transfer Between Jurisdictions)

El procesador deberá **identificar y documentar la base legal o contractual** que respalde cualquier transferencia de PII fuera de la jurisdicción original del controlador.

A.2.5.3 - Países y organizaciones internacionales (Countries and International Organizations)

El procesador deberá **mantener un registro actualizado** de los países y organizaciones internacionales a los cuales pueda transferirse la PII.

A.2.5.4 - Registros de divulgación de PII a terceros (Records of PII Disclosure to Third Parties)

El procesador deberá **registrar las divulgaciones de PII** a terceros, especificando qué datos fueron compartidos, con quién, y cuándo.

A.2.5.5 - Notificación de solicitudes de divulgación (Notification of Disclosure Requests)
El procesador deberá **notificar al controlador** cualquier solicitud de divulgación de PII proveniente de autoridades o terceros, salvo que exista una prohibición legal de hacerlo.

A.2.5.6 - Divulgaciones legalmente vinculantes (Legally Binding Disclosures)
Cuando el procesador esté **obligado por ley** a divulgar PII, deberá hacerlo **únicamente dentro del marco legal**, informando al controlador cuando sea posible.

A.2.5.7 - Divulgación de subcontratistas (Disclosure of Subcontractors)
El procesador deberá **informar al controlador** sobre todos los subcontratistas que participen en el tratamiento de PII.

A.2.5.8 - Contratación de subcontratistas (Engagement of Subcontractors)
El procesador deberá obtener **autorización previa y documentada del controlador** antes de contratar subprocesadores para el tratamiento de PII.

A.2.5.9 - Cambio de subcontratista (Change of Subcontractor)
El procesador deberá **notificar con antelación suficiente** al controlador sobre cualquier cambio en la lista de subprocesadores involucrados en el tratamiento de PII.

Tabla A.3 — Controles de seguridad de la información aplicables a Controladores y Procesadores de PII

Seguridad de la información para el tratamiento de PII

Objetivo:

Asegurar la **protección, integridad, disponibilidad y confidencialidad** de la información personal identificable (PII) durante su procesamiento, almacenamiento, transmisión y eliminación.

A.3.3 - Políticas de seguridad de la información
Las políticas de seguridad de la información relacionadas con el procesamiento de PII deberán ser **definidas, aprobadas por la dirección, publicadas, comunicadas y reconocidas** por el personal y las partes interesadas relevantes. Deberán revisarse periódicamente o cuando ocurran **cambios significativos** en el entorno de seguridad o en el tratamiento de PII.

A.3.4 - Roles y responsabilidades en seguridad de la información
Los **roles y responsabilidades** relacionados con la seguridad de la información deberán ser **definidos y asignados** conforme a las necesidades organizacionales, garantizando la **segregación de funciones** cuando sea necesario.

A.3.5 - Clasificación de la información

La información deberá clasificarse considerando las necesidades de seguridad de la organización, tomando en cuenta los principios de **confidencialidad, integridad y disponibilidad**, así como los requerimientos de las partes interesadas.

A.3.6 - Etiquetado de la información

Se deberán **definir e implementar procedimientos de etiquetado** coherentes con el esquema de clasificación adoptado, asegurando que los activos que contengan PII sean identificables y tratados conforme a su nivel de sensibilidad.

A.3.7 - Transferencia de información

Se deberán establecer **reglas, procedimientos o acuerdos formales de transferencia de información** relacionados con el tratamiento de PII, aplicables tanto dentro de la organización como entre organizaciones externas.

A.3.8 - Gestión de identidades

El **ciclo de vida completo de las identidades** relacionadas con el procesamiento de PII deberá ser gestionado, incluyendo la creación, modificación, revocación y eliminación de accesos.

A.3.18 - Acuerdos de confidencialidad o no divulgación

Los acuerdos de confidencialidad (NDA) que reflejen las necesidades de protección de PII de la organización deberán ser **identificados, documentados, revisados periódicamente y firmados** por el personal y las partes interesadas relevantes.

A.3.19 - Escritorio y pantalla limpios

Se deberán establecer y aplicar **reglas de escritorio y pantalla limpios**, abarcando tanto documentos físicos como dispositivos electrónicos o medios removibles.

A.3.20 - Medios de almacenamiento

Los medios que contengan PII deberán ser **gestionados durante todo su ciclo de vida** (adquisición, uso, transporte y disposición final), conforme al esquema de clasificación y las políticas de manejo seguro.

A.3.21 - Eliminación o reutilización segura de equipos

Antes de la **disposición o reutilización** de equipos que contengan medios de almacenamiento con PII, deberá **verificarse que los datos y software sensibles hayan sido eliminados o sobrescritos de forma segura**.

A.3.22 - Dispositivos de usuario final (endpoint devices)
La PII **almacenada, procesada o accesible** desde dispositivos de usuario final deberá estar **protegida mediante medidas de seguridad** adecuadas (cifrado, bloqueo remoto, gestión MDM, etc.).

A.3.23 - Autenticación segura
Deberán implementarse **tecnologías y procedimientos de autenticación segura** relacionados con el procesamiento de PII, en función de las **restricciones de acceso** definidas.

A.3.24 - Copias de respaldo (Backups)
Deberán mantenerse y **probarse regularmente** las copias de respaldo de la PII, así como de los sistemas y software relacionados con su procesamiento, para garantizar la recuperación ante incidentes.

A.3.25 - Registro de actividades (Logging)
Deberán **generarse, almacenarse, protegerse y analizarse registros (logs)** de actividades, excepciones, errores y eventos relevantes relacionados con el tratamiento de PII.

A.3.26 - Uso de criptografía
Se deberán **definir e implementar reglas** para el uso efectivo de la **criptografía** en el procesamiento de PII, incluyendo la **gestión de claves criptográficas**.

A.3.27 - Ciclo de vida de desarrollo seguro (Secure Development Life Cycle)
Deberán establecerse y aplicarse **reglas para el desarrollo seguro de software y sistemas** relacionados con el procesamiento de PII.

A.3.28 - Requisitos de seguridad en aplicaciones
Los **requisitos de seguridad de la información** relativos al procesamiento de PII deberán **identificarse, especificarse y aprobarse** durante el desarrollo o adquisición de aplicaciones.

A.3.29 - Arquitectura y principios de ingeniería segura
Se deberán **definir, documentar, mantener y aplicar principios de ingeniería segura** para todos los sistemas que procesen PII, integrando la seguridad desde el diseño ("**privacy by design**").

A.3.30 - Desarrollo subcontratado
La organización deberá **supervisar, dirigir y revisar** las actividades de desarrollo de sistemas de procesamiento de PII cuando sean **tercerizadas o subcontratadas**.

A.3.31 - Información de prueba (Test Data)
La información utilizada en entornos de prueba relacionada con PII deberá ser **adecuadamente**

seleccionada, protegida y gestionada.
Cuando sea posible, deberá utilizarse **PII ficticia o anonimizada**, aplicando controles equivalentes a los del entorno productivo.

Anexo B (Normativo)

Guía de implementación para Controladores y Procesadores de Información Personal Identificable (PII)

Este anexo brinda **orientación práctica (Implementation Guidance)** para aplicar los controles establecidos en el **Anexo A**, diferenciando las responsabilidades de **Controladores de PII (B.1)**, **Procesadores de PII (B.2)** y aquellas aplicables a **ambos (B.3)**.

B.1 Guía de implementación para Controladores de PII

B.1.1 Generalidades

Esta sección proporciona orientación para la implementación del **Sistema de Gestión de la Información de Privacidad (PIMS)** aplicable a los **controladores de datos personales**, vinculada a los controles listados en la **Tabla A.1**.

B.1.2 Condiciones para la recolección y procesamiento

Objetivo:

Demostrar que el tratamiento de PII es **lícito**, basado en una **base legal válida**, y con **finés específicos y legítimos**.

B.1.2.2 Identificación y documentación del propósito:

La organización debe **identificar y documentar los propósitos específicos** del tratamiento de PII, garantizando que los titulares comprendan por qué y para qué se usan sus datos. Debe mantenerse evidencia documental suficiente para demostrar transparencia y cumplimiento.

B.1.2.3 Base legal del procesamiento:

El controlador deberá determinar y documentar la **base jurídica aplicable**, como:

- consentimiento informado,
- ejecución contractual,
- cumplimiento de obligación legal,
- protección de intereses vitales,
- interés público o ejercicio de autoridad,
- interés legítimo del controlador.

El cumplimiento de la base legal debe poder **demostrarse ante la autoridad competente**.

B.1.5 Transferencia y divulgación de PII

B.1.5.3 Países y organizaciones internacionales:
El controlador deberá **documentar y comunicar los países y organizaciones** a los que la PII puede ser transferida, considerando también los subprocesadores involucrados.

B.1.5.4 Registros de transferencia de PII:
Se deberán **mantener registros** de todas las transferencias de PII hacia o desde terceros, aplicando el principio de minimización y conservando la información solo por el tiempo estrictamente necesario.

B.1.5.5 Registros de divulgación a terceros:
Las divulgaciones deberán registrarse con detalle: **qué datos, a quién y cuándo**, incluyendo las divulgaciones por auditorías o requerimientos legales.

B.2 Guía de implementación para Procesadores de PII

B.2.1 Generalidades

Esta sección provee orientación para la aplicación de los controles de la **Tabla A.2**, destinados a procesadores que actúan en nombre de controladores.

B.2.2 Condiciones para la recolección y procesamiento

B.2.2.1 **Objetivo:**
Demostrar que el procesamiento de PII se realiza conforme a una **base legal válida**, bajo **contrato documentado** con el controlador, y con **propósitos legítimos**.

B.2.2.2 Acuerdo con el cliente:
El procesador deberá asegurar que el contrato defina claramente:

- su rol en la asistencia al controlador,
 - los mecanismos de cooperación,
 - y los límites del tratamiento autorizado.
-

B.2.5.9 Cambios de subcontratistas (Change of Subcontractor)

Si el procesador planea cambiar o incorporar subprocesadores, deberá **informar previamente al controlador**, otorgándole la oportunidad de objetar el cambio o solicitar su autorización expresa. Estos mecanismos deben documentarse en el contrato o en acuerdos adicionales ("one-off agreements").

B.3 Guía de implementación para Controladores y Procesadores

B.3.1 Objetivo

Garantizar la **seguridad del procesamiento de PII**, alineando las políticas de privacidad y seguridad de la información.

B.3.2 Generalidades

Esta sección se aplica a ambos roles. Salvo disposiciones específicas, las mismas directrices son válidas tanto para **controladores** como para **procesadores**.

B.3.3 Políticas de seguridad de la información

Las políticas de seguridad relacionadas con el procesamiento de PII deberán:

- Ser **aprobadas por la dirección**,
 - **Publicadas y comunicadas** al personal y partes interesadas,
 - Revisarse **periódicamente o ante cambios significativos**,
 - Reflejar el compromiso de **cumplimiento legal y contractual**, incluyendo obligaciones con socios, subcontratistas y terceros.
-

B.3.4 Roles y responsabilidades de seguridad de la información

Los roles y responsabilidades deberán:

- Estar **definidos y asignados** según las necesidades organizativas.
 - Incluir un **punto de contacto designado** para consultas de clientes o titulares de datos.
 - Designar a una o más personas responsables de la **gobernanza y cumplimiento de privacidad**, que:
 - o reporten directamente a la alta dirección,
 - o gestionen todos los temas vinculados al tratamiento de PII,
 - o y promuevan la cultura de privacidad en la organización.
-

B.3.25 Registro de actividades (Logging)

Se deberán mantener **registros de eventos relacionados con PII**, incluyendo accesos, modificaciones y errores.

Los registros deberán revisarse periódicamente, idealmente mediante **monitoreo automatizado**, y conservarse conforme al calendario de retención definido. El acceso a los logs deberá limitarse estrictamente y protegerse de modificaciones o acceso indebido.

B.3.26 Uso de criptografía

Las reglas de uso de criptografía deberán estar **definidas y documentadas**, incluyendo la gestión de claves.

Algunas jurisdicciones pueden requerir cifrado obligatorio para ciertos tipos de PII (como datos de salud, identificación o pasaportes).

El procesador deberá **informar al cliente** sobre el uso de criptografía y las capacidades disponibles para su aplicación.

B.3.27 Ciclo de vida de desarrollo seguro

El desarrollo de sistemas o software que traten PII deberá incorporar **privacidad desde el diseño (Privacy by Design)** y **por defecto (Privacy by Default)**. Las políticas de desarrollo deben considerar:

- los requisitos legales aplicables,
- los riesgos de privacidad asociados,
- y los controles técnicos necesarios durante todo el ciclo de vida.

Anexo C (Informativo)

Correspondencia entre ISO/IEC 27701:2025, ISO/IEC 27001 e ISO/IEC 27002

Propósito

El objetivo de este anexo es **facilitar la alineación e integración** del Sistema de Gestión de la Información de Privacidad (**PIMS**) con los Sistemas de Gestión de Seguridad de la Información (**SGSI**) basados en **ISO/IEC 27001** y las guías de control de **ISO/IEC 27002**.

La correspondencia muestra cómo los **requisitos y controles de privacidad** establecidos en ISO/IEC 27701 pueden **correlacionarse o complementarse** con los controles de seguridad de la información definidos en ISO/IEC 27001 y 27002.

Importante: La relación mostrada no implica equivalencia estricta; debe considerarse como una **correspondencia indicativa** que ayuda a evitar redundancias y garantizar coherencia entre ambos sistemas.

Relación general entre los estándares

Área	ISO/IEC 27001	ISO/IEC 27002	ISO/IEC 27701:2025 (PIMS)	Descripción / Enfoque combinado
Contexto organizacional	Cláusula 4	—	Cláusula 4	Define el alcance, las partes interesadas y los factores internos/externos tanto de seguridad como de privacidad.
Liderazgo y política	Cláusula 5	5.1	Cláusula 5	Establece la política integrada de seguridad y privacidad. La dirección debe demostrar compromiso con ambos sistemas.
Planificación y riesgos	Cláusula 6	6.1–6.3	Cláusula 6	En 27701, los riesgos se amplían a los riesgos de privacidad (Privacy Risk Assessment) .
Soporte y documentación	Cláusula 7	7.2–7.5	Cláusula 7	Incluye recursos, competencias, concientización y control documental para evidenciar cumplimiento de protección de

Área	ISO/IEC 27001	ISO/IEC 27002	ISO/IEC 27701:2025 (PIMS)	Descripción / Enfoque combinado
				datos.
Operación y control	Cláusula 8	8.1-8.4	Cláusula 8	Ambas normas exigen controles operativos documentados; 27701 añade el tratamiento de PII y la gestión de consentimientos .
Evaluación del desempeño	Cláusula 9	9.1-9.3	Cláusula 9	Auditorías internas y revisión por la dirección unificadas para SGSI + PIMS.
Mejora continua	Cláusula 10	—	Cláusula 10	PDCA aplicado tanto a seguridad como a privacidad.

Correspondencia entre controles técnicos y de gestión

ISO/IEC 27002 (control)	Control equivalente / relacionado en ISO/IEC 27701	Ámbito de aplicación
5.1 Política de seguridad de la información	A.3.3 Políticas de seguridad de la información	Ambos
6.2 Organización de la seguridad	A.3.4 Roles y responsabilidades	Ambos
7.2 Concientización, educación y entrenamiento	A.3.18 Acuerdos de confidencialidad y formación en privacidad	Ambos
8.3 Gestión de medios	A.3.20 Medios de almacenamiento y eliminación	Ambos
9.2 Control de acceso de usuarios	A.3.8 Gestión de identidades / A.3.9 Derechos de acceso	Ambos
10.1 Cifrado de la información	A.3.26 Uso de criptografía y gestión de claves	Ambos
11.1 Seguridad física y ambiental	A.3.21 Eliminación segura de equipos y medios	Ambos
12.2 Gestión de cambios	A.3.31 Información de pruebas y cambio de sistemas	Ambos
13.2 Relaciones con proveedores	A.3.10 Seguridad en acuerdos con proveedores	Ambos
14.2 Desarrollo seguro de software	A.3.27 Ciclo de vida de desarrollo seguro / A.3.28 Requisitos de seguridad en aplicaciones	Ambos
15.1 Gestión de incidentes	B.3.25 Registro y análisis de actividades / logs de incidentes	Ambos
18.1 Cumplimiento legal y contractual	A.1.2.3 Base legal / A.1.5 Transferencias internacionales	Controladores de PII

Integración práctica SGSI + PIMS

1. Controles

compartidos:

Todos los controles de **ISO 27001 / 27002** se aplican a 27701 con enfoque ampliado a **datos personales (PII)**.

2. Controles exclusivos de 27701:

- ☐ Obtención y registro del **consentimiento**.
- ☐ Gestión de **solicitudes de titulares**.
- ☐ Mecanismos de **transferencia transfronteriza**.
- ☐ Registro y notificación de **incidentes de privacidad**.

3. Declaración de aplicabilidad combinada (SoA Integrada):

Se recomienda una **única SoA** que incluya tanto los controles ISO 27001 como los 27701, indicando:

- ☐ Estado de implementación.
- ☐ Evidencia disponible.
- ☐ Responsable y justificación.

Anexo D (Informativo)

Correspondencia con el Reglamento General de Protección de Datos (GDPR) de la Unión Europea

Propósito

Este anexo proporciona una correspondencia indicativa entre los **controles y requisitos de ISO/IEC 27701:2025** y los **artículos relevantes del Reglamento (UE) 2016/679 (GDPR)**. Su finalidad es **facilitar la evaluación de cumplimiento y equivalencia normativa** entre el marco ISO y la legislación europea de protección de datos.

Nota

importante:

La correspondencia no implica cumplimiento automático del GDPR. Se trata de un instrumento de apoyo para demostrar **alineación funcional** entre la norma ISO y la legislación.

Relación entre cláusulas ISO/IEC 27701:2025 y artículos del GDPR

Referencia ISO/IEC 27701:2025	Artículo del GDPR	Tema principal
5.2, 6.2	Art. 5, 6, 24	Principios de tratamiento y responsabilidad del controlador
A.1.2.2-A.1.2.4	Art. 6-9	Licitud del tratamiento, consentimiento y categorías especiales de datos
A.1.4.4-A.1.4.8	Art. 5(1)(c-e)	Minimización, exactitud y limitación de conservación
A.1.5.2-A.1.5.4	Art. 44-49	Transferencias internacionales de datos

Referencia 27701:2025	ISO/IEC	Artículo del GDPR	Tema principal
B.2.5.5–B.2.5.9		Art. 28–29	Procesadores, subprocesadores y contratos
B.3.25		Art. 30–33	Registro de actividades y notificación de incidentes
B.3.26–B.3.27		Art. 25, 32	Privacy by Design / Privacy by Default y seguridad del tratamiento
9.3		Art. 24, 35	Revisión por la dirección / Evaluación de impacto (DPIA)
10.2		Art. 34	Comunicación de brechas de datos a titulares
B.1.2.3		Art. 7	Condiciones del consentimiento
B.3.18		Art. 13–15	Transparencia e información a los titulares
B.2.4.3		Art. 28(3)(h)	Eliminación o devolución de datos al final del tratamiento

Interpretación

Esta tabla muestra cómo los **controles ISO/IEC 27701** cubren los **principios de responsabilidad proactiva** (accountability) exigidos por el GDPR, permitiendo a las organizaciones demostrar conformidad **mediante evidencia documental y mecanismos de auditoría**.

Anexo E (Informativo)

Mapeo con ISO/IEC 27018 e ISO/IEC 29151

Propósito

Este anexo describe el **vínculo entre ISO/IEC 27701:2025, ISO/IEC 27018:2019** (protección de datos personales en servicios de nube pública para procesadores) y **ISO/IEC 29151:2017** (controles adicionales de privacidad para controladores de PII).

Sirve como referencia para organizaciones que implementan **modelos híbridos o multinormativos**, por ejemplo:

- proveedores de servicios en la nube (cloud processors),
 - entidades que procesan datos personales de terceros,
 - y organizaciones que buscan certificaciones conjuntas (ISO 27001 + 27701 + 27018).
-

Relación entre las normas

Subcláusula ISO/IEC 27701:2025	Subcláusula ISO/IEC 27018 en	Subcláusula ISO/IEC 29151 en	Ámbito / Aplicación
B.3.3-B.3.16	5.1-5.36, A.10-A.11	5.1-5.36	Seguridad organizacional y técnica general para PII
B.3.17-B.3.18	6.3, 6.6, A.11.1	6.3, 6.6	Seguridad operacional, monitoreo y respuesta a incidentes
A.1.2.2-A.1.2.5	5.4-5.7	5.5-5.9	Licitud, consentimiento y transparencia
A.1.4.3-A.1.4.8	5.12-5.18	5.13-5.20	Minimización, exactitud y retención
A.1.5.2-A.1.5.4	5.31-5.36	5.35-5.36	Transferencias internacionales y cooperación entre partes
A.3.25-A.3.27	A.10.1-A.11.10	A.11.8-A.11.11	Seguridad, logging y desarrollo seguro

Nota:

Los vínculos son **indicativos**; no implican correspondencia exacta entre controles. Las organizaciones deben determinar qué controles son **pertinentes y equivalentes** según su contexto de operación (por ejemplo, cloud pública, PaaS, SaaS o IaaS).

Resumen práctico

- **ISO/IEC 27018:** se centra en **proveedores de servicios cloud**, actuando como **procesadores**.
- **ISO/IEC 29151:** amplía los **controles para controladores** de PII (quienes determinan fines y medios del tratamiento).
- **ISO/IEC 27701:** sirve de **marco integrador** que permite a ambos tipos de organizaciones establecer un **PIMS certificado** y trazable con los marcos de seguridad de ISO 27001/27002.

Anexo F (Informativo)

Correspondencia con ISO/IEC 27701:2019

Propósito

El propósito de este anexo es proporcionar **compatibilidad retroactiva** con la edición anterior de la norma, **ISO/IEC 27701:2019**, para aquellas organizaciones que ya utilizaban dicha versión y desean **migrar o actualizar su sistema de gestión de privacidad (PIMS)** a la versión **ISO/IEC 27701:2025**.

La **Tabla F.1** establece la correspondencia entre los **controles especificados en el Anexo A** de esta edición y los de la versión 2019.

- Las filas marcadas como **“N/A”** en la primera columna indican controles **nuevos** en 2025 (no presentes en 2019).
- Las filas con **“New”** en la segunda columna representan **controles que no existían** en la versión anterior y que fueron **introducidos por primera vez en 2025**.

Tabla F.1 — Correspondencia entre controles en ISO/IEC 27701:2025 y 27701:2019

ISO/IEC 27701:2025 (control)	ISO/IEC 27701:2019 (control)	Nombre del control
A.3.3	6.2.1.1, 6.2.1.2	Políticas de seguridad de la información
A.3.4	6.3.1.1	Roles y responsabilidades en seguridad de la información
—	6.3.1.2	Segregación de funciones <i>(eliminado en 2025)</i>
—	6.3.1.4	Contacto con grupos de interés <i>(eliminado)</i>
—	6.5.1.3	Uso aceptable de activos <i>(reemplazado por controles de medios)</i>
A.3.5	6.5.2.1	Clasificación de la información
A.3.6	6.5.2.2	Etiquetado de la información
A.3.7	6.10.2.1–6.10.2.3	Transferencia de información
A.3.8	6.6.2.1	Gestión de identidades
A.3.9	6.6.2.2, 6.6.2.5, 6.6.2.6	Derechos de acceso
A.3.20	6.5.3.1–6.5.3.3	Gestión y eliminación de medios
A.3.24	6.9.3.1	Copias de respaldo
A.3.25	6.9.4.1–6.9.4.3	Registros (Logging)
A.3.26	6.7.1.1–6.7.1.2	Uso de criptografía
A.3.27	6.11.2.1	Ciclo de vida de desarrollo seguro
A.3.28	6.11.1.2, 6.11.1.3	Requisitos de seguridad en aplicaciones
A.3.29	6.11.2.5	Principios de ingeniería segura
A.3.30	6.11.2.7	Desarrollo tercerizado
A.3.31	6.11.3.1	Información de prueba

Controles nuevos introducidos en la edición 2025

Control nuevo (2025)	Tema o alcance
Información y datos: eliminación (Information deletion)	Requisitos explícitos de borrado seguro y trazable de datos personales.
Enmascaramiento de datos (Data masking)	Aplicación de técnicas de seudonimización y anonimización como medida preventiva.
Prevención de fugas de datos (Data Leakage Prevention)	Establecimiento de controles de detección y bloqueo de filtraciones de información personal.
Monitoreo de actividades (Monitoring Activities)	Incorporación de mecanismos proactivos de observación, detección y alerta temprana de incidentes.
Filtrado web (Web Filtering)	Nuevo control sobre protección de la navegación y exposición a contenido o sitios de riesgo.
Codificación segura (Secure Coding)	Inclusión formal de estándares de codificación segura y validación de código fuente.

Controles eliminados o consolidados

Control eliminado (2019) Razonamiento / Cambio en 2025

Contacto con autoridades	Reasignado bajo gestión de incidentes y cumplimiento legal.
Contacto con grupos de interés	Reemplazado por políticas de comunicación de privacidad (cláusula 7.4).
Procedimientos disciplinarios	Eliminado por redundancia; abordado por políticas de recursos humanos en SGSI.
Gestión de accesos privilegiados	Integrado dentro de gestión de identidades (A.3.8 y A.3.9).
Seguridad de redes	Reemplazada por “seguridad en servicios de red” dentro de 27002 y mapeada indirectamente.

Tabla F.2 — Correspondencia inversa (27701:2019 → 27701:2025)

ISO/IEC 27701:2019 (control)	ISO/IEC 27701:2025 (control)	Nombre del control según la edición 2019
6.2.1.1	A.3.3	Políticas para la seguridad de la información
6.3.1.1	A.3.4	Roles internos y responsabilidades de seguridad
6.5.2.1	A.3.5	Clasificación de información
6.5.2.2	A.3.6	Etiquetado de información
6.7.1.1–6.7.1.2	A.3.26	Uso de criptografía
6.11.2.1	A.3.27	Ciclo de vida de desarrollo seguro
6.11.2.5	A.3.29	Principios de ingeniería segura
6.11.3.1	A.3.31	Información de prueba (test data)
—	A.3.24–A.3.30	Controles ampliados de backup, registro, y monitoreo

Resumen del Anexo F

Este anexo permite a las organizaciones **mapear su sistema de gestión anterior (2019)** con el **nuevo esquema 2025**, garantizando continuidad en certificaciones y auditorías. Las principales **novedades** introducidas por la versión 2025 son:

- Incorporación de controles específicos de **protección de datos y prevención de fuga (DLP)**.
- Refuerzo del enfoque de **seguridad por diseño y codificación segura**.
- Mayor alineación con **ISO 27002:2022** y **GDPR**.
- Clarificación de la **integración SGSI + PIMS** bajo un marco unificado.

Recomendaciones para la Implementación del PIMS – ISO/IEC 27701:2025

1. Síntesis general

La norma **ISO/IEC 27701:2025** consolida el marco internacional de referencia para la **gestión de la información de privacidad (PIMS)**, extendiendo los principios de **seguridad de la información (SGSI – ISO/IEC 27001)** hacia la **protección de datos personales (PII)**.

Esta edición 2025 incorpora mejoras sustanciales frente a su versión 2019, tales como:

- Mayor **alineación con ISO/IEC 27002:2022**,
- Correspondencia directa con el **Reglamento General de Protección de Datos (GDPR)**,
- Introducción de controles de **Prevención de Pérdida de Datos (DLP)**, **codificación segura y monitoreo proactivo de incidentes de privacidad**,
- Y un modelo de **integración operativa** que permite auditar y certificar el PIMS dentro del mismo ciclo del SGSI.

Las organizaciones que ya cuentan con un **SGSI certificado** pueden **ampliar su alcance** incorporando los controles de privacidad definidos en esta norma, sin necesidad de duplicar procesos.

2. Alcance operativo

Un **PIMS basado en ISO/IEC 27701:2025** debe cubrir de manera integrada:

Área de Gestión	Objetivo Principal	Instrumento de Control
Gobierno y liderazgo	Definir roles, políticas y compromiso directivo	Cláusulas 5 y 7
Gestión de riesgos	Identificar y tratar riesgos de privacidad y seguridad	Cláusula 6
Gestión de datos personales	Establecer base legal, consentimiento y derechos de titulares	Anexo A (A.1 y A.2)
Seguridad técnica y operativa	Proteger, registrar, cifrar y eliminar datos personales	Anexo A (A.3)

Área de Gestión	Objetivo Principal	Instrumento de Control
Cumplimiento y auditoría	Monitorear conformidad y mejora continua	Cláusulas 9 y 10
Interoperabilidad normativa	Alinear SGSI, GDPR, ISO 27018 y 29151	Anexos C, D y E

3. Recomendaciones para implementación

3.1 Integración con el SGSI

- Incorporar el **PIMS como una extensión del SGSI** existente, bajo una política común de seguridad y privacidad.
- Unificar los documentos de gestión (SoA, Matriz RACI, Registro de Activos, Evaluación de Riesgos).
- Mantener trazabilidad entre los **controles ISO 27001** y los **controles de privacidad 27701**, especialmente en los anexos A.1–A.3.

3.2 Gobernanza y roles

- Designar un **Responsable de Privacidad o DPO (Data Protection Officer)** que actúe como enlace entre áreas técnicas, legales y de cumplimiento.
- Formalizar la responsabilidad del **CISO o Gerente de Seguridad** en el soporte técnico y monitoreo continuo del PIMS.

3.3 Ciclo de vida de la información personal

- Definir claramente las **bases legales** del tratamiento (consentimiento, obligación contractual, interés legítimo, etc.).
- Implementar políticas de **retención y eliminación** de PII con evidencias trazables.
- Mantener procedimientos específicos para **transferencias internacionales, subprocesadores y requerimientos legales o regulatorios**.

3.4 Medidas técnicas

- Aplicar cifrado, seudonimización, anonimización y controles de acceso basados en riesgo.
- Incorporar herramientas de **Data Loss Prevention (DLP)**, **SIEM** y **automatización de auditoría**.
- Implementar **monitoreo continuo** de incidentes de privacidad y mecanismos de **alerta temprana**.

3.5 Mejora continua

- Revisar el PIMS en conjunto con el SGSI al menos una vez al año.
 - Incluir indicadores de desempeño específicos de privacidad (**KPI/PPI de privacidad**).
 - Mantener un programa permanente de **concientización y capacitación** en privacidad y protección de datos.
-

4. Beneficios esperados

La adopción integral de la norma ISO/IEC 27701:2025 genera beneficios tangibles tanto en términos técnicos como estratégicos:

Categoría	Beneficio Clave
Cumplimiento regulatorio	Alineación directa con GDPR, Ley 25.326 (Argentina), LGPD (Brasil) y otras legislaciones de privacidad.
Confianza del cliente	Evidencia certificable de protección de la información personal.
Ventaja competitiva	Diferenciación comercial y preferencia en contratos internacionales.
Resiliencia organizacional	Capacidad de respuesta ante incidentes de privacidad o fugas de datos.
Eficiencia operativa	Integración del PIMS al SGSI sin duplicar procesos o documentación.

5. Recomendación final

Se recomienda a las organizaciones que implementen esta versión **adoptar un enfoque por etapas**, comenzando por:

1. **Evaluación de brecha** (gap analysis) frente a ISO 27701:2025.
2. **Actualización del SoA y mapa de riesgos de privacidad**.
3. **Alineación documental** (políticas, procedimientos, registros).
4. **Auditoría interna conjunta SGSI-PIMS**.
5. **Certificación o extensión de alcance** ante el organismo certificador correspondiente.

Matriz de Correspondencia y Trazabilidad de Privacidad y Seguridad de la Información, que integre en un solo documento los siguientes marcos:

- **ISO/IEC 27701:2025** – Privacidad y PIMS
- **ISO/IEC 27001:2022** – SGSI
- **GDPR (UE 2016/679)** – Reglamento General de Protección de Datos
- **Ley 25.326 (Argentina)** – Protección de Datos Personales

Cláusula / Control ISO 27701:2025	Cláusula Control ISO 27001:2022	Artículo GDPR	Artículo Ley 25.326 (AR)	Descripción / Objetivo de Control	Evidencia o Documento Asociado
A.1.2.2 - Identificar y documentar el propósito del tratamiento	6.1.2 - Identificación de requisitos de seguridad	Art. 5.1(a), 6	Art. 2 y 4	Definir y justificar la finalidad del tratamiento de datos personales.	Política de Privacidad / Registro de Actividades
A.1.2.4 - Consentimiento del titular	7.4 - Comunicación de requisitos de seguridad	Art. 7, 8	Art. 5, 6	Establecer procesos de obtención, registro y retiro del consentimiento.	Formulario de Consentimiento / Base de Datos de Consentimientos
A.1.4.8 - Retención de PII	8.1 - Operación y control operacional	Art. 5.1(e)	Art. 4(1)(3)	Limitar la conservación de datos personales al tiempo necesario.	Política de Retención y Eliminación / Registro de Borrado
A.1.5.2 - Transferencias internacionales	5.1 - Liderazgo y compromiso	Art. 44-49	Art. 12	Garantizar cumplimiento en transferencias de datos fuera del país.	Contratos de Transferencia / Cláusulas Modelo
A.3.26 - Uso de criptografía	A.10.1 - Cifrado de la información	Art. 32	Art. 9(h)	Proteger PII mediante cifrado y gestión de claves seguras.	Política de Criptografía / Registro de Llaves
B.3.25 - Logging y monitoreo de actividades	A.12.4 - Registro y monitoreo de eventos	Art. 30, 33	Art. 9(g)	Mantener trazabilidad de accesos y auditorías sobre PII.	Logs de Auditoría / SIEM / Reportes de Incidentes
B.3.27 - Privacy by Design / Default	A.14.2 - Desarrollo seguro	Art. 25	Art. 9(j)	Incorporar privacidad desde el diseño en procesos y sistemas.	Procedimiento de Desarrollo Seguro / Evidencia de Pruebas
10.2 - No conformidades y acciones correctivas	10.2 - Acción correctiva	Art. 24, 35	Art. 21	Gestionar y documentar incidentes y mejoras en el PIMS.	Registro de No Conformidades / Informe de Incidente